Plan de Gouvernance des Données — Spotify

Table des matières

1. Résumé Exécutif
2. État des Lieux et Maturité
3. Cadre de Gouvernance et Principes
4. Classification des Données
5. Modèle Organisationnel (Centre d'Excellence)
6. Stratégie Technologique
7. Conformité Réglementaire
8. Programme d'Audit
9. Évaluation et Gestion des Risques
10. Plan de Mise en Œuvre
11. KPIs et Métriques de Succès
12. Budget et Ressources
13. Conduite du Changement
14. Accessibilité et Inclusion
15. Références

---

1. Résumé Exécutif

Spotify est une organisation dont la maturité analytique est de classe mondiale (Niveau 5), portée par 675 millions d'utilisateurs actifs mensuels et un chiffre d'affaires de 15,67 milliards EUR en 2024 — sa première année entièrement profitable (source : rapport T4 2024). Cependant, l'expansion mondiale rapide de l'entreprise a engendré des silos de données profonds et une gouvernance fragmentée (Niveau 2), créant un écart dangereux entre les capacités technologiques et la maturité de la gestion des données.

Le Comité de Direction de Spotify approuve le présent Plan de Gouvernance des Données comme feuille de route contraignante pour faire passer l'organisation d'un modèle de gouvernance réactif à un modèle géré (Niveau 4) dans un horizon de 18 mois.

Enjeux principaux :

- **Risque réglementaire** : une infraction au RGPD peut générer une amende allant jusqu'à 628 millions EUR (4 % du CA 2024). Un précédent direct existe dans le secteur : Netflix condamné à 4,75M EUR en 2024 ; Deezer sanctionné suite à la fuite de 46 millions de profils.
- **Risque de qualité** : des métadonnées "sales" dégradent la précision de Discover Weekly et des radios personnalisées, augmentant le churn. Une réduction de 0,1 point du taux de churn Premium représente ~15 millions EUR de revenus annuels préservés.
- **Risque stratégique** : l'absence de catalogue de données et de standards communs freine la collaboration cross-départementale et ralentit les cycles d'innovation.

Ce plan est structuré en 3 phases sur 18 mois avec des KPIs de sortie de phase clairs, un budget estimé à 1,68M EUR sur la période, et un ROI projeté supérieur à x10 sur 3 ans.

---

2. État des Lieux et Maturité

L'évaluation conduite conformément au référentiel DMBOK v2 révèle un contraste fort entre l'excellence technologique et la fragmentation organisationnelle :

Dimension	Niveau Actuel	Niveau Cible (18 mois)	Observations Clés
Analytics & BI	5	5	Algorithmes ML de classe mondiale ; traitement temps réel. Maintenir.
Littératie des Données	4	4	Culture data-driven ancrée ; fort taux d'adoption interne.
Sécurité des Données	4	4	Chiffrement robuste et logs d'audit standards (PCI-DSS).
Qualité des Données	3	4	Élevée pour le produit, mais variable et non mesurée pour Marketing/Finance.
Conformité Réglementaire	3	4	RGPD/CCPA en place, mais difficile à mettre à l'échelle dans 180+ pays.
Gouvernance des Données	2	4	Gestion départementale ; absence de cadre d'entreprise unifié. **Priorité #1.**
Intégration des Données	2	4	Silos profonds entre Marketing, Produit et Engineering. **Priorité #2.**
Architecture des Données	3	4	Stack moderne mais sans catalogue ni glossaire commun.

Score global actuel : 3,25/5 → Cible : 4,0/5

Défis Majeurs

1. **Silos de données** : Vues utilisateurs contradictoires selon les départements, duplication des traitements, impossibilité de réaliser des analyses cross-départementales fiables.
2. **Mise à l'échelle de la conformité** : Processus semi-manuels dans 180+ pays, risque élevé d'erreur humaine sur les DSAR, politique de confidentialité jugée trop complexe (précédent enquête autorité allemande, 2023).
3. **Érosion de la qualité** : Aucune mesure formelle du taux de complétude des métadonnées. Risque d'effet "garbage-in/garbage-out" sur les modèles ML de recommandation.

---

3. Cadre de Gouvernance et Principes

La présente politique de gouvernance repose sur quatre piliers fondamentaux, conformes aux principes du DMBOK v2 et aux exigences de l'article 5 du RGPD :

1. **La donnée comme actif stratégique** : Toute donnée produite ou acquise par Spotify est un actif de l'entreprise — pas un actif départemental — et doit être gérée pour maximiser sa valeur commerciale et minimiser les risques associés.
2. **Qualité à la source** : La responsabilité de la qualité d'une donnée incombe à son créateur ou au système d'origine. Les contrôles de qualité sont implémentés au plus tôt dans le pipeline (principe "shift-left"), pas en aval.
3. **Privacy by Design** (RGPD Art. 25) : La confidentialité et la sécurité sont intégrées dans la conception de tout produit, service ou système traitant des données personnelles. Elles ne sont jamais ajoutées à posteriori.
4. **Transparence et responsabilité** : Toutes les activités de traitement sont transparentes pour les utilisateurs, les régulateurs et les équipes internes. Une traçabilité complète est maintenue pour toutes les données à fort impact.

---

4. Classification des Données

Le Comité de Direction approuve la taxonomie de classification suivante, applicable à l'ensemble des données Spotify :

Niveau	Désignation	Exemples Spotify	Contrôles requis
N1	**Public**	Catalogues publics, données de popularité agrégées	Aucune restriction
N2	**Interne**	Rapports internes, présentations, données de test anonymisées	Accès authentifié (SSO)
N3	**Confidentiel**	Données d'engagement utilisateur, métadonnées, données marketing	RBAC + chiffrement en transit + revue semestrielle des accès
N4	**Restreint**	PII, données de paiement, clés de chiffrement	AES-256 au repos + MFA + logs exhaustifs + revue trimestrielle

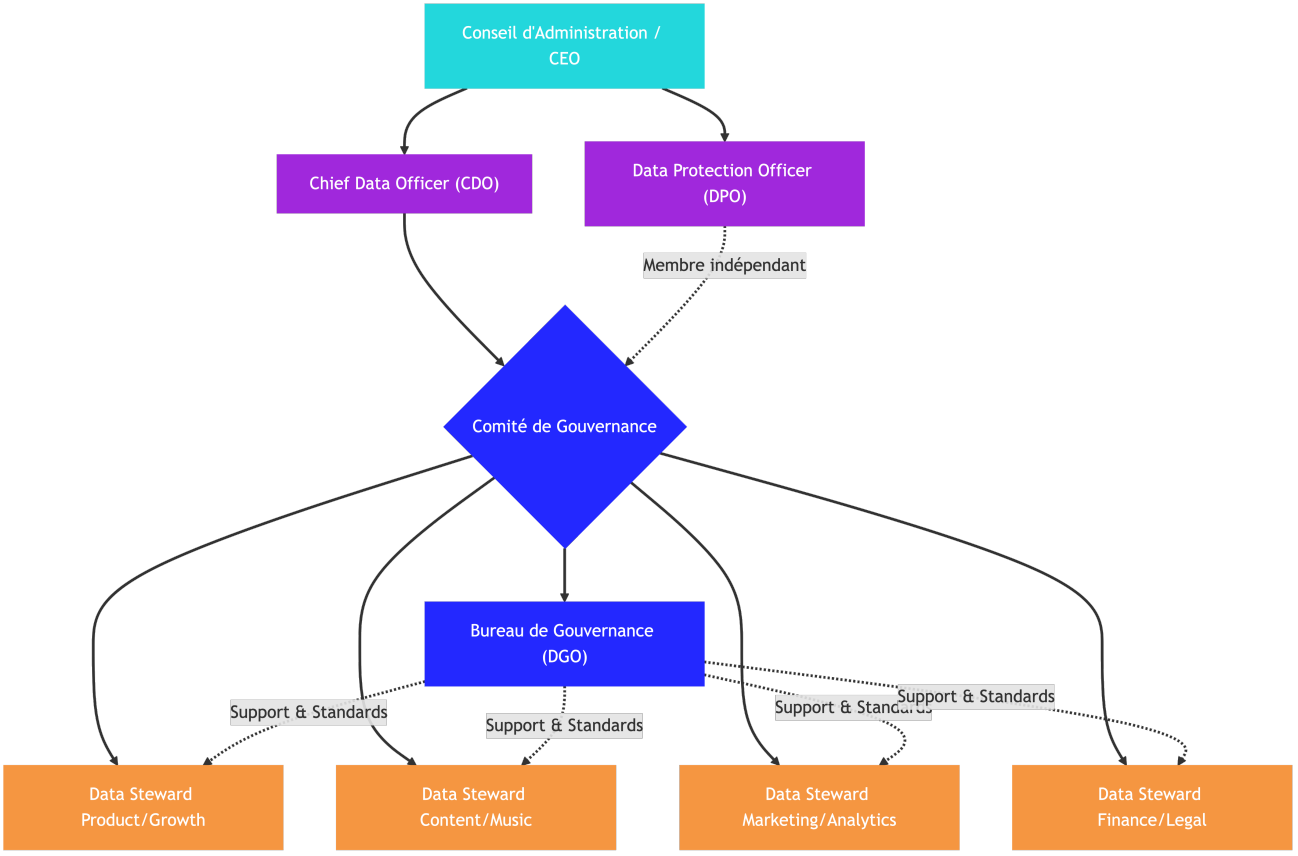
5. Modèle Organisationnel (Centre d'Excellence)

Le Comité de Direction approuve l'adoption du **modèle Centre d'Excellence (CoE) hybride**, après évaluation des alternatives (modèle centralisé et modèle fédéré).

Justification : Le modèle centralisé est incompatible avec la culture Squad de Spotify (trop lent, trop prescriptif). Le modèle fédéré perpétuerait les silos existants. Le CoE permet d'unifier les standards et les outils tout en préservant l'autonomie et l'expertise des équipes métier.

Hiérarchie approuvée :

- **Chief Data Officer (CDO)** : Sponsor exécutif, rattaché au CTO/CEO. Rôle existant.
- **Data Protection Officer (DPO)** : Surveillance indépendante de la conformité (RGPD Art. 37-39). Rattaché à la Direction Juridique.
- **Comité de Gouvernance des Données (DGC)** : Instance de décision transversale. Réunion mensuelle. Président : CDO.
- **Bureau de Gouvernance des Données (DGO)** : Équipe opérationnelle de 4-5 personnes, dirigée par un Directeur de Gouvernance (DGD) recruté en Phase 1.
- **Data Stewards** : Experts métier par domaine (Utilisateurs, Métadonnées Contenu, Finance, Marketing). Nommés en Phase 1.



6. Stratégie Technologique

Déploiement d'une stack "Modern Data Governance" sur 18 mois :

Outil	Catégorie	Fonction	Phase de déploiement
Alation	Catalogue de données	Source unique de vérité pour la découverte, le lignage et le glossaire métier. Sélectionné vs DataHub (maintenance open source trop lourde en Phase 1) et Collibra (coût supérieur).	Phase 1
Soda.io	Qualité des données	Monitoring automatisé des données, alertes, "data quality as code". Sélectionné vs Great Expectations (courbe d'apprentissage plus élevée pour les profils métier).	Phase 2
OneTrust	Confidentialité / Consentement	Gestion globale du consentement, automation des DSAR multi-juridictions (RGPD/CCPA/PDPA). Leader du marché (Gartner 2024).	Phase 2
Monte Carlo	Observabilité des pipelines	Détection proactive des anomalies (data freshness, volume drift, schema drift). Alertes avant impact produit.	Phase 3

Perspective Data Mesh : À horizon 3 ans, et si la maturité de gouvernance atteint le Niveau 4 sur toutes les dimensions, une migration vers une architecture Data Mesh (domaines de données autonomes avec Data Contracts) sera évaluée. Le CoE pose les fondations nécessaires à cette évolution.

---

7. Conformité Réglementaire

7.1 RGPD (UE 2016/679)

- **Mécanisme de consentement** : Plateforme OneTrust gérant le consentement dans les 180+ pays. Enregistrement de chaque consentement avec horodatage, version de la politique, et canal de collecte.
- **Gestion des DSAR** : Workflow unifié OneTrust. SLA : accusé de réception sous 72h, réponse complète sous 30 jours (Art. 12). Processus entièrement automatisé en Phase 2.
- **Notification de violation** (Art. 33) : Notification à l'autorité compétente dans les 72h suivant la découverte. Chaîne d'alerte formalisée : équipe de sécurité → DPO → CDO → autorité. Documentation systématique.
- **Privacy by Design** (Art. 25) : Checklist PbD obligatoire pour tout nouveau produit ou fonctionnalité traitant des données personnelles, avant mise en production.

7.2 CCPA (Cal. Civ. Code § 1798.100)

Intégré dans le workflow DSAR unifié OneTrust. Bouton "Do Not Sell My Information" sur toutes les interfaces Spotify (web, mobile, TV).

7.3 PCI-DSS v4.0

Chiffrement AES-256 et tokenisation de toutes les données de paiement. Tests de pénétration trimestriels. Maintien du niveau PCI-DSS 1.

7.4 Réglementations Émergentes

- **EU AI Act** : Les systèmes de recommandation algorithmique de Spotify sont classés "risque limité". Obligations : transparence envers les utilisateurs, documentation technique des modèles, mesures anti-biais. Mise en conformité en Phase 2-3.
- **PDPA (Singapour)** : Pris en compte dans le périmètre OneTrust dès Phase 2.

---

8. Programme d'Audit

Le Comité de Direction approuve le programme d'audit suivant, conformément à l'exigence du référentiel Bloc 1 ("Conduct regular audits of the company's data management practices") :

8.1 Audits internes

Audit	Fréquence	Responsable	Périmètre	Livrable
Audit de qualité des données	Trimestriel	DGO (Analystes)	Tous les jeux de données monitorés par Soda.io	Rapport de qualité avec tendances
Revue des accès (N3/N4)	Trimestriel (N4) / Semestriel (N3)	DGO + RSSI	Tous les accès aux données Confidentiel et Restreint	Liste des accès revus et éventuelle révocation
Audit de conformité DSAR	Mensuel	DPO	100 % des DSAR du mois écoulé	Taux de conformité SLA, incidents identifiés
Audit de maturité globale	Annuel	DGO + DPO	Toutes les dimensions DMBOK	Rapport de maturité avec score et plan d'action

8.2 Audit externe annuel

- Un cabinet indépendant mandaté par le Conseil d'Administration conduit un audit complet de la gouvernance des données chaque année, incluant la conformité RGPD/CCPA et la sécurité des données.
- Premier audit externe prévu en Phase 3 (Mois 16-18).
- Rapport d'audit transmis au Conseil d'Administration et aux autorités de contrôle si requis.

8.3 Rapports de gouvernance

Le DGO produit un **tableau de bord de gouvernance mensuel** présenté au DGC, incluant : état des KPIs, incidents en cours, avancement des phases, alertes réglementaires.

---

9. Évaluation et Gestion des Risques

9.1 Matrice des risques principaux

#	Risque	Probabilité	Impact	Score	Mitigation	Owner
R1	*Résistance au changement des équipes*	Haute	Moyen	9	Réseau de champions ; communication CDO ; quick wins visibles dès Mois 3	DGD + CDO
R2	*Violation de données pendant la transition*	Faible	Critique	9	Procédure 72h opérationnelle ; OneTrust prioritaire ; pentest trimestriel	DPO + RSSI
R3	*Retard procurement Alation*	Moyenne	Haut	9	Lancement achat Mois 1 ; DataHub en contingence	DGD + Achats
R4	*Turnover des Data Stewards*	Moyenne	Haut	6	Documentation des rôles ; backup par domaine ; intégration OKR	DGD + RH
R5	*Dépassement budgétaire*	Moyenne	Moyen	6	Réserve 15 % ; arbitrage CDO si dépassement	CDO + Finance
R6	*Échec du pilote*	Faible	Haut	4	Revue Mois 6 ; critères d'arrêt clairs ; périmètre limité	DGD + DGC
R7	*Nouveau texte réglementaire*	Faible	Moyen	3	Veille réglementaire mensuelle DPO ; cadre conçu pour être évolutif	DPO

Score = Probabilité (1-3) x Impact (1-3). R1-R3 sont les risques prioritaires.

9.2 Dispositif de surveillance des risques

- Revue mensuelle du registre des risques par le DGC.
- Tout nouveau risque R >= 6 déclenche un plan d'action sous 2 semaines.
- Le rapport d'audit annuel inclut une mise à jour complète de la cartographie des risques.

---

10. Plan de Mise en Œuvre

Phase 1 : Fondation (Mois 1-3)

Objectif : Poser les bases institutionnelles. Aucun outil de gouvernance ne peut être déployé sans cette phase.

Actions clés :

- Recrutement du Directeur de Gouvernance (DGD) et constitution de l'équipe DGO (4 personnes)
- Validation et signature de la Politique de Gouvernance par le Comité de Direction
- Nomination des 4 Data Stewards par domaine métier
- Sélection et procurement de l'outil catalogue Alation
- Installation d'Alation sur les 3 principales sources de données
- Première session du DGC

Livrables : Équipe DGO opérationnelle | Politique signée | 4 Stewards nommés | Alation v0 déployé

Exit criteria :

- [ ] 4 personnes recrutées dans le DGO
- [ ] Politique signée par le CDO et le Comité de Direction
- [ ] Alation connecté à >= 3 sources de données
- [ ] 4 Data Stewards nommés et formés aux fondamentaux

Phase 2 : Programme Pilote (Mois 4-9)

Objectif : Valider le framework sur le périmètre des métadonnées de recommandation avant tout déploiement global.

Actions clés :

- Profiling initial des métadonnées de pistes (établissement de la baseline)
- Déploiement des règles de qualité Soda.io dans le pipeline d'ingestion
- Déploiement OneTrust — automation des DSAR (RGPD/CCPA/PDPA)
- Formation des Stewards aux outils
- Revue à mi-parcours (Mois 6) avec décision Go/Ajustement/No-Go

Livrables : Rapport de baseline | Règles Soda.io en production | DSAR automatisés | Rapport pilote Mois 9

Exit criteria :

- [ ] Complétude métadonnées >= 92 %
- [ ] 100 % des DSAR traités en <= 30 jours
- [ ] 0 alerte critique non traitée pendant 30 jours consécutifs

---

Phase 3 : Déploiement Global (Mois 10-18)

Objectif : Étendre le framework à l'ensemble de l'organisation et ancrer la culture de gouvernance.

Actions clés :

- Extension Alation à tous les lacs et entrepôts de données
- Déploiement Soda.io sur les pipelines Marketing et Finance
- Déploiement Monte Carlo (observabilité complète)
- Programme de certification "Data Stewardship" pour tous les rôles data-facing
- Formation obligatoire tous employés (WCAG 2.1 AA)
- Premier audit externe annuel

Livrables : Catalogue 100 % couvert | Monitoring global | Rapport d'audit externe | v2.0 Politique de Gouvernance

Exit criteria :

- [ ] Score de maturité >= 4/5 sur toutes les dimensions
- [ ] Complétude métadonnées >= 97 %
- [ ] 0 pénalité réglementaire sur la période
- [ ] Taux complétion formation >= 95 %

---

11. KPIs et Métriques de Succès

KPI	Baseline	Cible 6 mois	Cible 18 mois	Responsable	Fréquence	Outil
Complétude métadonnées pistes	À mesurer	>= 92 %	>= 97 %	Steward Contenu	Hebdo	Soda.io
Taux de conformité DSAR (SLA 30j)	Partiel	90 %	100 %	DPO	Mensuel	OneTrust
Score de maturité globale (DMBOK)	3,25/5	3,5/5	>= 4,0/5	DGO	Trimestriel	Audit interne
Taux de couverture du catalogue (% datasets documentés)	~10 %	40 %	90 %	DGO	Mensuel	Alation
Nombre d'alertes qualité critiques non traitées	Non mesuré	< 5	0	DGO	Hebdo	Soda.io
Taux de complétion formation gouvernance	0 %	60 %	>= 95 %	DGO + L&D	Trimestriel	LMS interne
Délai moyen de résolution anomalie qualité	Non mesuré	< 48h	< 24h	Stewards	Mensuel	Soda.io
Taux de churn Premium	~1,3 %	Stable	<= 1,2 %	Data Science	Mensuel	Analytics interne

12. Budget et Ressources

Estimation T-shirt sizing — à affiner en Phase 1 avec Achats et Finance.

Poste	Phase 1 (M1-3)	Phase 2 (M4-9)	Phase 3 (M10-18)	Total
Équipe DGO (salaires)	150K EUR	300K EUR	300K EUR	**750K EUR**
Alation (licence + impl.)	80K EUR	80K EUR	80K EUR	**240K EUR**
Soda.io (licence + impl.)	30K EUR	30K EUR	30K EUR	**90K EUR**
OneTrust (licence + impl.)	60K EUR	30K EUR	30K EUR	**120K EUR**
Monte Carlo (licence + impl.)	—	40K EUR	40K EUR	**80K EUR**
Formation & Change Management	20K EUR	30K EUR	80K EUR	**130K EUR**
Audit externe annuel	—	—	50K EUR	**50K EUR**
Réserve (15 %)	51K EUR	78K EUR	90K EUR	**219K EUR**
TOTAL	**391K EUR**	**588K EUR**	**700K EUR**	**~1,68M EUR**

ROI synthétique :

- Amendes RGPD évitées : valeur d'assurance estimée à plusieurs dizaines de millions EUR (amende max = 628M EUR sur base CA 2024).
- Rétention améliorée : -0,1 pt de churn = ~15M EUR de revenus préservés/an (calcul : 263M abonnés x ARPU 4,69 EUR/mois x 12).
- Gains d'efficacité : élimination des duplications, accès plus rapide aux données (~5M EUR/an estimatif).
- **ROI projeté >= x10 sur 3 ans.**

---

13. Conduite du Changement

La mise en œuvre d'un programme de gouvernance échoue dans 70 % des cas non pas pour des raisons techniques, mais pour des raisons humaines (source : Gartner). La conduite du changement est donc un investissement prioritaire, non une option.

13.1 Plan de communication

- **Message CDO (Mois 1)** : Communication institutionnelle du CDO à toute l'organisation expliquant le "pourquoi" du programme, les bénéfices attendus et le calendrier.
- **Newsletters mensuelles** du DGO : avancement, quick wins, témoignages de Stewards.
- **Tableau de bord public interne** : suivi des KPIs de gouvernance visible de tous.

13.2 Réseau de Champions

- Identification de 1-2 "Data Champions" par BU (collaborateurs influents et convaincus par le programme).
- Rôle : relais de communication, premiers testeurs des outils, remontée du terrain.
- Animation : réunions trimestrielles des Champions + reconnaissance formelle.

13.3 Quick Wins (impact immédiat avant la fin de Phase 1)

1. **Audit flash des métadonnées de Discover Weekly** (2 semaines) : premier chiffre de baseline publié en interne → crédibilise le programme.
2. **Glossaire métier partagé** (Mois 2) : résout immédiatement les ambiguïtés de terminologie entre Marketing et Engineering.
3. **Tableau de bord de qualité temps réel** (Mois 3, périmètre pilote) : rend visible l'amélioration continue.

13.4 Formation par vagues

- **Vague 1 (Mois 2-3)** : DGO + Data Stewards — formation intensive DMBOK + outils.
- **Vague 2 (Mois 6-9)** : Data Owners et équipes data-facing — formation intermédiaire.
- **Vague 3 (Mois 12-18)** : Tous employés — formation de sensibilisation obligatoire.

---

14. Accessibilité et Inclusion

Conformément aux exigences du Bloc 1 (formation inclusive) et aux obligations légales (RGAA v4.1 / WCAG 2.1) :

- **Formation universellement accessible :** Tous les modules de formation à la gouvernance sont conçus et audités pour être accessibles aux collaborateurs en situation de handicap — sous-titrage automatique et manuel, compatibilité lecteurs d'écran (NVDA, JAWS, VoiceOver), contrastes élevés (ratio >= 4,5:1), formats alternatifs disponibles (PDF structuré, version audio).
- **Outils gouvernance audités :** Le choix d'Alation et d'OneTrust intègre des critères de conformité WCAG 2.1 niveau AA dans la grille de sélection. Tout outil ne satisfaisant pas ce critère est disqualifié.
- **Processus inclusifs :** La définition des standards de gouvernance (politiques, règles de qualité, glossaire) inclut des collaborateurs représentatifs de la diversité des situations de handicap.
- **Indicateur de suivi :** Le taux de complétion de la formation >= 95 % est mesuré de manière désagrégée pour s'assurer de l'absence d'écart lié à une situation de handicap.

---

15. Références

- DAMA International — *DMBOK v2 : Data Management Body of Knowledge*, 2017
- Spotify Newsroom — *Q4 2024 Earnings*, 4 février 2025
- RGPD — Règlement (UE) 2016/679, Art. 4, 5, 6, 12, 15-22, 25, 28, 33, 34, 37-39
- CCPA — Cal. Civ. Code § 1798.100 et seq.
- EU AI Act — Règlement (UE) 2024/1689
- PCI-DSS v4.0 — PCI Security Standards Council
- Gartner — *Magic Quadrant for Data and Analytics Governance Solutions*, 2024